Technical Report: Final Limitations and Recommendations

Student Name: Cassiana de Oliveira
Student Number: L00188357

1. Final Limitations

Some limitations were encountered during the execution of this assignment. Sentinel, for example, does not see the running cloud, only the plan. That means that console changes, resources made outside of Terraform and values known only after "apply" are not checked. Another limitation is that data from Ireland can still be subjected to international law if the provider is based on other countries. Also, administrative and support access and who holds encryption keys are invisible to a plan.

There are, also, some coverage gaps, such as the fact that only EBS snapshot and AMI copies are checked for replication, not S3 replication or RDS backups. Additionally, no test makes the availability-zone rule or the standalone security-group rule fail. Because rules are joined with 'and', Sentinel stops at the first failure rule, so HCP trace listed only the instance type, although the plan also held open SSH and us-east-1a.

The Free edition allows five policies in one policy set and only one hard-mandatory policy, so sovereignty and supply chain had to be set advisory, that means a run that breaks only those two policies would still be able to proceed to apply. Mocks are hand-written and contain only the fields each policy reads. The compliant HCP run was the check against real plan data.

In the supply chain, Sentinel checks the declared source and version, not the downloaded bytes. Hashes are verified by terraform init, and the first CI run failed because the lock file only held the Windows hash.

2. Recommendations

Recommendations were formulated based on limitations encountered during the implementation. It is important to make all policies hard-mandatory and load them from version control so the deployed policy is the reviewed one. Add an AWS Organizations service control policy with aws:RequestedRegion, so the region limit holds even if Terraform or Sentinel is bypassed. Also, strengthen data control with customer-managed KMS keys, checks for S3 replication, RDS backups and logs, and separate control of IAM and administrative access. Additionally, protect the policies themselves by branch protection and required review for sentinel/, ideally in a separate policy repository with a named owner. Add failing tests for the uncovered rules, build mocks from real plans, review policies when providers change, and add scheduled plans or drift detection to cover what plan time cannot.

3. Declaration of AI tool Use

Tool: Claude. Model: Claude Sonnet 5.5. Period: 9 to 13 November 2026. Tool: DeepSeek. Model: DeepSeek-V3. Period: 9 to 13 November 2026. The main prompts are listed in section 10 of the README.